

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 – Information Security Governance

WEEK 1 PRACTICAL LABORATORY

Information Security Governance in Action

GlobalHealth Connect (GHC) — Executive Governance Simulation

Student Name	Abigail Ugoeze Silas
Registration Number	C11/26/CGRCE/17260
Course	GRC102 – Information Security Governance
Module	Module 1 – Principles of Information Security Governance
Submission Date	11 September 2026
Access Window	05–11 September 2026

Table of Contents

Task 1 – Governance Blueprint	3
Task 2 – Information Security Charter	8
Task 3 – Board Reporting and Security Metrics	13
Task 4 – Security Steering Committee	17
Task 5 – Governance Maturity Assessment	21
References	26

TASK 1 — GOVERNANCE BLUEPRINT

1A. Current-State Governance Gap Assessment

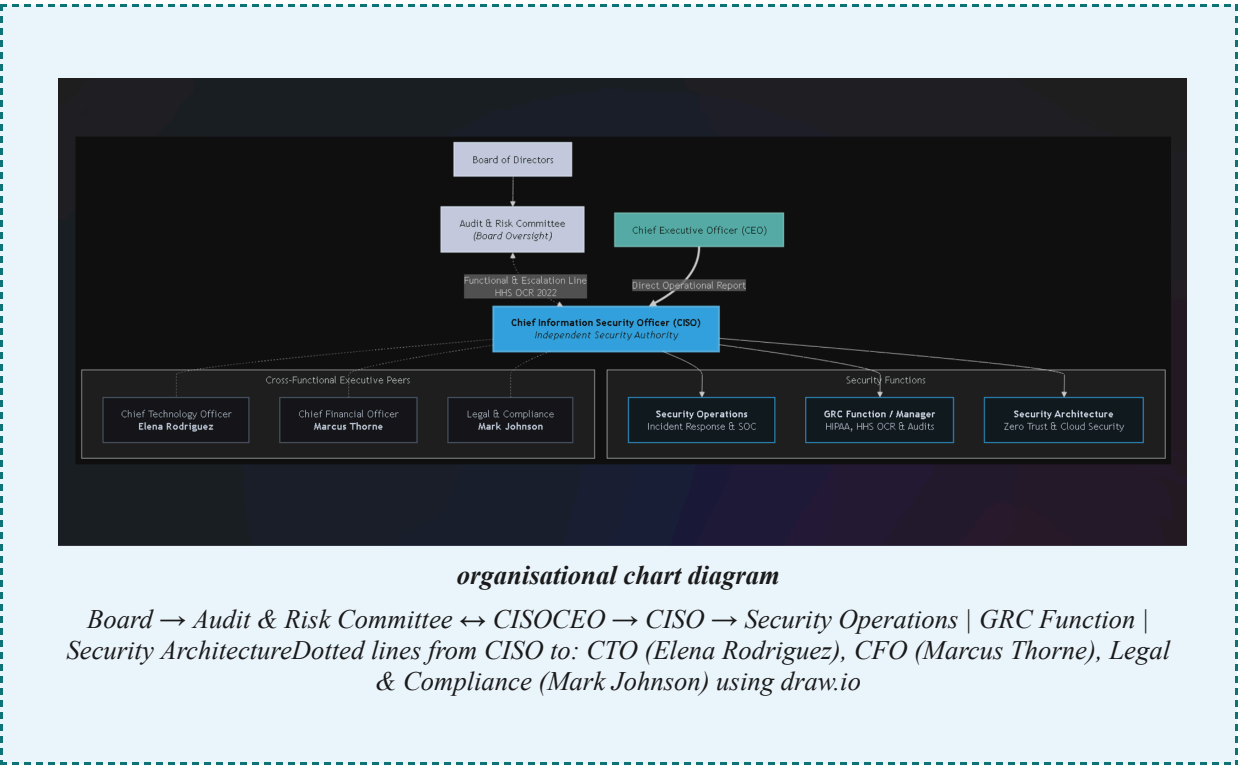
The following assessment identifies critical weaknesses in GHC's ad-hoc security model, drawing on the organisational context provided and governance principles aligned with ISO/IEC 27001:2022 and NIST Cybersecurity Framework (CSF) 2.0.

#	Gap Area	Current State	Risk Implication	Priority
1	No Dedicated Security Leadership	Security responsibilities are informally distributed across IT Operations, Legal & Compliance, and Development without central coordination or a designated CISO.	No single point of accountability; security decisions are delayed, inconsistent, or missed entirely. The recent near-miss demonstrates this risk.	CRITICAL
2	Absent Policy Framework	Policies inherited through two acquisitions are inconsistent, unvalidated and not harmonised. No master policy register exists.	Regulatory non-compliance (e.g., HIPAA) and operational confusion. Staff cannot follow policies they cannot find or reconcile.	HIGH
3	No Formal Risk Management Process	Risk identification is reactive, triggered by incidents rather than proactive periodic assessment.	Emerging threats and systemic vulnerabilities go undetected. The Board cannot make risk-informed investment decisions.	CRITICAL
4	Undefined Accountability (No RACI)	Ownership of key security activities (incident response, access management, third-party oversight) is unclear across departments.	Activities fall between teams; no individual bears defined responsibility, creating execution gaps during crises.	HIGH
5	No Board-Level Security Reporting	Security metrics exist at a technical level but are not translated into business impact or presented to the Board.	The Board cannot discharge its fiduciary duty to oversee cyber risk, exposing GHC to governance failures and regulatory scrutiny.	HIGH
6	Cross-Functional Governance Vacuum	No forum exists for resolving security disputes between departments (e.g., the current CTO vs. IT Manager password-policy conflict).	Security decisions default to departmental preference rather than enterprise risk appetite, creating inconsistent controls.	MEDIUM
7	Post-Acquisition Integration Risk	Two recent acquisitions have not undergone security harmonisation, leaving orphaned user accounts, unknown systems, and conflicting configurations.	Unknown attack surface; potential regulatory liability inherited from acquired entities.	HIGH
8	Low Security Training Engagement	Mandatory annual training exists but participation reached only 45% in the earliest recorded month.	Human-factor vulnerabilities remain elevated; phishing and	MEDIUM

#	Gap Area	Current State	Risk Implication	Priority
			social engineering risks are unmitigated.	

1B. Proposed Security Governance Organisational Chart

The proposed structure introduces a dedicated Chief Information Security Officer (CISO) reporting directly to the CEO, with a functional dotted line to the Board's Audit and Risk Committee. This establishes independent authority, direct executive access and clear escalation pathways consistent with healthcare sector governance expectations (HHS OCR, 2022).



Narrative Description of Chart Structure

Level	Entity / Role	Reporting Relationship	Rationale
1 – Oversight	Board of Directors → Audit & Risk Committee	Receives quarterly CISO reporting; approves risk appetite	Ensures board-level accountability for cyber risk as required under HIPAA Security Rule §164.308(a)(1)
2 – Executive	CEO (Sarah Chen)	CISO reports directly to CEO	Elevates security as a business function, not an IT sub-task; signals organisational priority
2 – Governance	CISO (New Role)	Reports to CEO; dotted line to Audit & Risk Committee	Central accountability for security governance, strategy and compliance
3 – Operational	Security Operations Lead	Reports to CISO	Day-to-day monitoring, incident response, and vulnerability management
3 – Governance	GRC Manager (Mark Johnson)	Reports to CISO; coordinates with	Policy, compliance, risk management and audit liaison

Level	Entity / Role	Reporting Relationship	Rationale
		Legal & Compliance	
3 – Technical	Security Architecture Lead	Reports to CISO; embedded liaison with CTO team	Secure-by-design integration with product development and cloud operations
4 – Embedded	Security Champions (Jane Doe + others)	Embedded in Development; functional link to CISO	Bring security into the SDLC without creating development bottlenecks

1C. RACI Responsibility Matrix

Key: R = **Responsible** (performs the work) | A = **Accountable** (owns the outcome) | C = **Consulted** (input sought) | I = **Informed** (notified of outcome)

Governance Activity	Board / Audit Ctte	CEO	CISO	CTO	CFO	GRC Manager	IT Manager	Compliance Officer	HR Manager	Dev Lead
Policy Approval & Review	A	A	R	C	C	R	C	C	I	I
Information Security Risk Review	I	A	R	C	C	R	C	C	I	I
Incident Response Planning	I	I	A	C	I	R	R	C	C	C
Security Awareness Training	I	I	A	I	I	R	C	I	R	I
Third-Party Risk Management	I	I	A	C	C	R	C	R	I	I
Compliance Monitoring (HIPAA)	I	I	A	C	C	R	I	R	I	I
Security Architecture Review	I	I	A	C	I	C	R	I	I	R
Access Management & Offboarding	I	I	A	I	I	C	R	I	R	I
Board Security Reporting	I	C	R	I	C	R	I	I	I	I

Governance Activity	Board / Audit Ctte	CEO	CISO	CTO	CFO	GRC Manager	IT Manager	Compliance Officer	HR Manager	Dev Lead
Security Budget Planning	I	C	R	C	A	C	C	I	I	I

1D. Governance Structure Rationale

Accountability

The appointment of the CISO role gathers accountability, which is currently scattered throughout the organization. An accountable individual takes responsibility for security outcomes and reports to the CEO, addressing the ambiguity issue which caused the near miss. The use of the RACI matrix allows for accountability to be made explicit and measurable, crucial under HIPAA Administrative Safeguards (45 CFR §164.308).

Transparency

The CISO's quarterly reporting to the Audit and Risk Committee along with monthly executive metrics provides the Board of Directors with timely and accurate information on the state of security at GHC. This reflects the principle outlined in the UK Corporate Governance Code, according to which boards need to receive enough information to exercise proper oversight (FRC, 2024), an internationally applicable principle in the field of health care governance.

Business Alignment

Security Architecture has been placed in the governance structure and has a formal liaison into Elena Rodriguez's CTO organization. Thus, security considerations become part of the product development life cycle and help achieve one of the strategic goals of GHC: promoting innovations using AI without introducing unacceptable risks. Security Champions embedded into Development support business alignment at the team level.

Risk Managemet

The GRC Manager role (initially leveraging Mark Johnson's regulatory expertise) introduces proactive risk identification, replacing the current reactive posture. A formal risk register, reviewed quarterly by the CISO and presented to the Audit Committee, creates the structured feedback loop needed for evidence-based governance (ISACA, 2023).

TASK 2 — INFORMATION SECURITY CHARTER

2A. GlobalHealth Connect — Information Security Charter

Document Field	Detail
Document Title	GlobalHealth Connect — Information Security Charter
Version	1.0
Status	DRAFT — Pending Executive Approval
Owner	Chief Information Security Officer (CISO)
Approver	Chief Executive Officer / Board of Directors
Classification	Internal — Restricted
Review Frequency	Annual (or following material change)
Effective Date	Upon board approval

1. Purpose

GlobalHealth Connect (GHC) offers cloud-based patient management solutions to healthcare organizations. Being the custodian of confidential health information as well as the burgeoning digital health infrastructure, GHC has a duty of ensuring that the confidentiality, integrity, and availability of such information assets are secured from any form of risk. This Charter creates the mandate, the authority, the scope, and the principles that govern GHC's Information Security Program. It forms the executive basis from which all the information security policies, standards, procedures, and controls derive their authority. The program is intended to:

- Ensure that patient health information and business-critical data assets of GHC are protected against any unauthorized access, modification, or destruction.
- Help GHC meet its obligations under the relevant regulations and agreements such as HIPAA, HITECH, relevant state privacy laws, and contractual obligations to healthcare clients.
- Facilitate strategic growth objectives of GHC by incorporating security as an enabler for competitiveness and not a compliance issue.
- Establish and maintain the confidence of patients, healthcare clients, investors, and regulators through security governance.

2. Scope

This Charter and the Information Security Programme it establishes apply to:

Scope Category	Coverage
Information Assets	All data created, processed, transmitted or stored by GHC, including protected health information (PHI), personally identifiable information (PII), financial records, intellectual property, client data, and internal business information, in any format.
Systems and Technology	All GHC-owned, leased or contracted IT systems, cloud platforms, software applications, networks, endpoints, storage systems, and development environments, including those introduced through acquisitions.
People	All GHC employees, contractors, consultants, interns, temporary staff, and board members who access GHC information or systems in any capacity.
Third Parties	All vendors, business associates, managed service providers and partners who process, store, transmit or have access to GHC information assets.

Scope Category	Coverage
	Business Associate Agreements (BAAs) are required where applicable under HIPAA.
Physical Locations	All GHC offices, data centres, co-location facilities, and any premises from which GHC staff access GHC information, including remote working arrangements.
Acquired Entities	All entities acquired by GHC from the date of acquisition, subject to a formal security integration timeline agreed with the CISO.

3. Authority

This Charter is authorised by the GHC Board of Directors and operates under the following authority hierarchy:

- The Board of Directors holds ultimate accountability for GHC's enterprise risk posture, including information security risk, and approves GHC's risk appetite and this Charter.
- The Audit and Risk Committee of the Board provides ongoing oversight of the Information Security Programme and receives quarterly security reporting from the CISO.
- The Chief Executive Officer (CEO) is accountable to the Board for implementing effective information security governance and delegates operational authority to the CISO.
- The Chief Information Security Officer (CISO) holds delegated authority to develop, implement and enforce the Information Security Programme, including the power to issue mandatory policies, direct security-related operational decisions, and escalate security risks to the CEO and Board.
- The CISO has the authority to pause or halt activities that present an unacceptable risk to GHC information assets, subject to CEO notification and Security Steering Committee review within 48 hours.

4. Roles and Responsibilities

High-level accountabilities are defined below. Detailed responsibilities are specified in GHC's RACI Responsibility Matrix (Information Security Governance) and role-specific security policies.

Role	Accountability
Board / Audit & Risk Committee	Approve risk appetite; receive quarterly security reporting; hold CEO accountable for security governance outcomes.
CEO (Sarah Chen)	Champion security as an organisational value; allocate adequate resources; ensure CISO has access and authority required.
CISO	Develop and maintain the Information Security Programme; manage risk; report to Board and CEO; chair Security Steering Committee.
CFO (Marcus Thorne)	Approve security budget; ensure financial risk from cyber incidents is reflected in enterprise risk management; co-sign material risk decisions.
CTO (Elena Rodriguez)	Ensure secure-by-design principles are applied in product development and technology operations; integrate security architecture into the technology roadmap.
GRC Manager (Mark Johnson)	Maintain policy framework; coordinate compliance monitoring; manage regulatory liaison; own risk register.
IT Manager (John Smith)	Implement security controls in infrastructure and operations; participate in incident response; report control status to CISO.
HR Manager (Robert Green)	Manage joiner/mover/leaver processes; coordinate security awareness training completion; conduct security screening.

Role	Accountability
All Staff	Complete mandatory security training; comply with GHC security policies; report suspected security incidents promptly.

5. Key Principles

Principle	Application at GHC
Risk-Based	Security investment and control stringency are proportionate to the risk posed to GHC's information assets, based on formal risk assessment. Not all information is treated equally.
Business-Aligned	Security decisions are made in the context of GHC's strategic objectives. Security is a business enabler. Controls are designed to support innovation, growth and operational efficiency, not obstruct them.
Proportionate	Controls match the sensitivity of the information and system being protected. Administrative burden is minimised for low-risk activities.
Privacy by Design	Patient privacy and data minimisation principles are embedded in all new products, features and processes from inception, consistent with HIPAA and applicable privacy frameworks.
Continuously Improving	The Programme is assessed against recognised maturity models annually. Improvement targets are set, funded and tracked as part of the business planning cycle.
Compliant by Default	GHC proactively monitors applicable regulatory obligations and embeds compliance into operational processes rather than preparing only for audits.
Transparent	Security posture, significant incidents and material risks are communicated honestly and promptly to appropriate stakeholders, including the Board, clients and regulators where required.

6. Reporting Structure

Reporting Channel	Frequency	Audience	Content
Board / Audit & Risk Committee Report	Quarterly	Board of Directors	RAG posture summary; key risk indicators; significant incidents; programme progress; resource adequacy.
Executive Security Dashboard	Monthly	CEO, CFO, CTO	Five key security metrics; emerging risks; remediation status; investment decisions required.
Security Steering Committee Report	Monthly	SSC Members (cross-functional)	Policy decisions; risk exceptions; project progress; cross-functional issues.
Operational Security Report	Weekly	CISO, IT Manager, Security Operations	Incident log; vulnerability status; patching KPIs; threat intelligence summary.
Major Incident Report	Event-driven (within 24hrs)	CEO, CFO, Board (as applicable)	Incident details; business impact; containment actions; regulatory notification status.

7. Review and Approval

This Charter shall be reviewed annually by the CISO and presented to the CEO for approval. An extraordinary review shall be initiated in the event of a significant change to GHC's risk profile, regulatory environment,

business model, or following any material security incident. Changes to the Charter require CEO approval and Board ratification. Version history is maintained in the GHC Document Management System.

Approved by:

Role	Name	Signature	Date
Chief Executive Officer	Sarah Chen	_____	_____
Board Chair / Audit Ctte Chair	[Name of Board Chair]	_____	_____

2B. Justification Memo to CFO

Memo Field	Detail
To	Marcus Thorne, Chief Financial Officer
From	CISO / Information Security Programme
Subject	GHC Information Security Charter — Strategic and Financial Rationale
Date	11 September 2026
Classification	Internal — Confidential

Dear Marcus,

I am writing this to outline the financial and strategic justification for your approval of the GHC Information Security Charter, prior to its submission to the Board in the upcoming governance meeting.

This charter documents the mandate, authority and accountability framework of the information security programme of GHC at an important stage in GHC's development process. From the point of view of financial risk, the recent near-miss data leak incident highlights the exposure the organization could be facing in case of an actual data breach. According to the IBM Security report, the mean cost of a data breach in the healthcare industry was \$9.77 million in 2024 (the highest among industries for the 14th consecutive year). Compared to this figure, it can be readily concluded that the expenditure on establishing a proper governance framework is certainly justified. Through this Charter, you will have the opportunity, as the CFO, to include cybersecurity risks in the enterprise risk management system with defined risk appetite, escalation procedures and financial risk metrics, shifting from the cost centre approach to security spending towards a risk management investment. Additionally, this will help you to demonstrate good faith efforts to comply with the HIPAA regulations through documentation of governance, named accountabilities and evidence of a security programme are preconditions for demonstrating good-faith compliance and mitigating civil monetary penalties in the event of a future enforcement action.

From a strategic alignment point of view, the Charter directly aligns to three out of five objectives that GHC aims to achieve in 2026. Firstly, the Charter ensures "Maintain Customer Trust" because it guarantees the protection of patient information. Second, through the establishment of governance around proactively ensuring compliance and not around audits as a reaction, "Regulatory Excellence" is achieved. Finally, "Market Share Expansion" will be facilitated through the Charter that ensures a security posture that healthcare providers increasingly demand from their vendors. In summary, security governance is not an overhead but a requirement for the company's next stage of development.

Regards,

Chief Information Security Officer, GlobalHealth Connect

TASK 3 — BOARD REPORTING AND SECURITY METRICS

3A. Board Executive Security Summary — Q4 2025 to Q1 2026

Document Field	Detail
Reporting Period	September 2025 – February 2026 (6 months)
Prepared by	CISO / Information Security Programme
Audience	GHC Board of Directors
Overall Posture Assessment	AMBER — Deteriorating

OVERALL SECURITY POSTURE

 **AMBER — Deteriorating**

The threat environment is escalating. Incident frequency has increased continuously over six months. Critical vulnerability remediation rates are declining. Board attention and resource allocation are required.

Reasoning for amber: The security state of GHC is graded amber due to the following reasons: (1) high priority security issues have increased from 2 to 7 within a period of six months which translates into an increase of 250%; (2) critical vulnerability fix rates have decreased from 67% to 55%; (3) threat environment (phishing and malware) has doubled. The amber grade is attributed to the fact that there is improvement in security awareness training (45% to 70%) and there has been no significant breach.

3B. Five Selected Security Metrics

Metric 1: High-Risk Security Incidents

Current Status (Feb) 7 incidents	6-Month Trend ↑ +250% (2 → 7)	Board-Level Commentary High risk incidents are the most appropriate proxy for business impact. Incidents of seven in February compared to only two in September indicate an unsustainable trend. Every incident takes up substantial time from employees, involves the responsibility of informing authorities and reduces customer confidence. An immediate inquiry into the underlying reasons is recommended.
--	---	--

Metric 2: Critical Vulnerability Remediation Rate

Current Status (Feb) 55% patched	6-Month Trend ↓ Declining (67% → 55%)	Board-Level Commentary Unpatched critical vulnerabilities represent open doors for attackers. GHC's rate has fallen from 67% to 55% while the total number of critical vulnerabilities has increased from 15 to 40 — meaning more vulnerabilities are going unaddressed in absolute terms. A patching rate below 80% for critical issues is generally considered unacceptable for healthcare systems handling PHI. A funded remediation acceleration plan is required within 30 days.
--	---	---

Metric 3: Security Awareness Training Completion

Current Status (Feb) 70% completion	6-Month Trend ↑ Improving (45% → 70%)	Board-Level Commentary This is GHC's single positive trend over the reporting period. Training completion has risen from 45% to 70%, reflecting improving staff engagement. However, 30% of staff remain untrained, and in a healthcare environment where phishing is the most common attack vector, this gap is material. The target should be 95% completion within the next quarter. HIPAA requires documented workforce training as a mandatory implementation specification (45 CFR §164.308(a)(5)).
---	---	---

Metric 4: Phishing Attempt Volume

Current Status (Feb) 320 attempts	6-Month Trend ↑ +113% (150 → 320)	Board-Level Commentary Phishing attempts against GHC have more than doubled in six months, reflecting broader industry trends but also indicating that GHC may be an increasingly targeted organisation as it grows. Without high training completion and strong email filtering controls, rising phishing volume directly increases the probability of a successful credential compromise or ransomware deployment. This metric should be read alongside the incident rate and training completion as a risk triad.
---	---	--

Metric 5: Malware Detection Events

Current Status (Feb) 50 detections	6-Month Trend ↑ +100% (25 → 50)	Board-Level Commentary There is a doubling of malware detections, which is consistent with the trend seen with phishing attacks. Although this is an indication that controls are working since malware is being detected, it also means that there is more operational work for the security teams as well as an increased likelihood that some malware incidents may go undetected. This measure is categorized as AMBER since there is an indication that controls are working.
--	---	--

3C. Priority Risks and Recommendations

Priority Risk	Business Impact	Recommended Action	Owner	Timeline
Declining Vulnerability Remediation	The existence of critical vulnerabilities that are unpatched in a PHD environment is HIPAA breach exposure and possible ransomware exploit, with the average cost of healthcare breach going above USD 9.77M (IBM, 2024).	Approve an emergency patching program: commit IT personnel to make sure the remediation of critical vulnerabilities exceeds 90% in 60 days. Consider using third party vulnerability management provider in case of lacking capacity.	CISO / IT Manager	30 days (approval); 60 days (target met)
Rising Incident Rate Without Governance Structure	Seven high-risk incidents in February without a formal incident response plan or CISO in post creates regulatory, reputational and operational risk. HHS OCR investigations are triggered by breach reports; the absence of	Prioritise CISO appointment and formal Incident Response Plan (IRP) development as the two most urgent governance actions. The IRP must include HIPAA Breach Notification Rule timelines (45 CFR §164.410) and clear escalation contacts.	CEO / Board	CISO appointment: 30 days; IRP: 60 days from CISO appointment

Priority Risk	Business Impact	Recommended Action	Owner	Timeline
	documented governance is an aggravating factor.			

3D. Metric Selection Rationale

All five metrics were chosen under the condition that Board oversight should be based on decision-useful information, rather than technical completeness. The selection criteria used were: (1) relevance to business/regulation impacts; (2) clarity of information to non-technical Board members; (3) trend (are we becoming safer or less safe over time?); and (4) actionability (can this metric point us towards a governance or investment decision?).

High-Risk Incidents is the primary output metric – it measures the harm caused to GHC by cyber threats. Vulnerability Remediation Rate is the most relevant predictive metric for likelihood of a breach in a cloud computing environment. Training Completion is the only positive trend and captures the human factor behind most threats. Phishing Volume sets up the context for the threat environment in which GHC operates and explains why training completion is important. Malware Detections completes the picture of the threats and is the leading indicator of the incidents metric. All five metrics together tell a clear story – the threat environment is getting worse, our defenses have not caught up with it, and there is one bright spot in it that needs to accelerate. This is the story that the Board should get resource and governance decisions (Calder and Watkins, 2010).

TASK 4 — SECURITY STEERING COMMITTEE

4A. Security Steering Committee — Terms of Reference

Document Field	Detail
Committee Name	GlobalHealth Connect — Security Steering Committee (SSC)
Version	1.0
Established by	Chief Executive Officer
Chair	Chief Information Security Officer (CISO)
Secretariat	GRC Manager
Meeting Cadence	Monthly (standing); extraordinary sessions as required with 48 hours notice
Reporting to	CEO; quarterly summary to Board Audit & Risk Committee

1. Purpose

The Security Steering Committee (SSC) is the primary cross-functional governance forum for information security at GlobalHealth Connect. It exists to ensure that security decisions are made at the appropriate level, with the right stakeholders represented, and in alignment with GHC's risk appetite, business objectives and regulatory obligations. The SSC provides the mechanism through which security strategy is translated into operational action and through which cross-functional conflicts are resolved in a structured, documented and accountable manner.

2. Scope of Authority

- Approval and acceptance of information security policies, standards, and procedures.
- Dispute resolution of security issues involving cross-functions and escalation of unresolved issues to the CEO.
- Review and approve/disapprove any formal risk exceptions that arise from business units.
- Prioritization of security roadmap and security investment recommendations to the CFO and CEO.
- Security project management of significant security projects and initiatives (including acquisition).
- Major incident review and approval of post-incident remediation strategy.
- Monitoring of GHC compliance program and approval of regulatory response strategies.

3. Membership

Member	Role / Designation	Voting Status	Rationale for Inclusion
CISO	Chair	Chair (casting vote only)	Provides security expertise and programme leadership; owns the agenda.
CEO (Sarah Chen)	Executive Sponsor	Yes	Ensures strategic alignment and provides executive authority for significant decisions.
CFO (Marcus Thorne)	Finance Representative	Yes	Enables risk-based investment decisions; ensures financial risk is considered.

Member	Role / Designation	Voting Status	Rationale for Inclusion
CTO (Elena Rodriguez)	Technology Representative	Yes	Ensures security is integrated with technology strategy and development operations.
GRC Manager (Mark Johnson)	Secretary / Compliance	Observer (advisory)	Provides regulatory and policy expertise; maintains minutes and action log.
IT Manager (John Smith)	Operations Representative	Yes	Represents operational security delivery; brings implementation perspective.
HR Manager (Robert Green)	People Risk Representative	Yes	Covers workforce-related security matters including training and insider risk.
Dev Lead (Jane Doe)	Development Representative	Yes	Ensures development team interests and constraints are represented in security decisions.
External Legal Counsel	As required — co-opted	Observer (advisory)	Provides regulatory and legal opinion on significant compliance or incident matters.

Quorum: The SSC is quorate with the Chair and any three voting members present. Decisions require a simple majority of voting members present. In the event of a tie, the Chair holds a casting vote. The Chair may defer a decision to an extraordinary session if the matter is sufficiently material and key members are absent.

4. Responsibilities

SSC Responsibility	Frequency	Output
Review security metrics dashboard and posture assessment	Monthly	Updated posture rating; escalation decisions
Consider policy approvals, amendments and retirements	As tabled	Approved / rejected policy with rationale
Review and adjudicate risk exceptions	As submitted	Accepted (with conditions) / rejected exception; risk register update
Resolve cross-functional security conflicts	As tabled	Documented decision with rationale; implementation instruction
Review significant incidents (Sev 1 & 2)	Monthly / event-driven	Post-incident review; approved remediation plan
Prioritise security roadmap initiatives	Quarterly	Updated priority list; investment recommendation to CEO/CFO
Review compliance programme status	Quarterly	Compliance dashboard; regulatory action log

5. Meeting Cadence and Administration

- Regular standing meetings take place on the second Tuesday of every month, from 10:00 – 11:30 WAT.
- The agenda and relevant documentation is issued by the GRC Manager at least five days before each meeting.

- The minutes of the meetings are issued within five working days after the meeting and are then approved in the next meeting.
- Action items are recorded in an active action log kept by the GRC Manager and discussed at the beginning of every meeting.
- Exceptional meetings can be arranged by the Chair or CEO, in case of important issues or emergencies, with 48 hours' notice.

6. Decision Authority and Escalation

Decision Type	SSC Authority	Escalation Path
Policy approval (standard)	Full authority to approve	None — SSC decision is final, subject to CEO ratification for tier-1 policies
Risk exception (low / medium)	Full authority to accept or reject	None
Risk exception (high / critical)	SSC recommends; CEO approves	CEO (with CISO brief) → Board notification if enterprise-level risk
Cross-functional policy dispute	SSC adjudicates; Chair casts deciding vote	CEO if SSC cannot reach quorate decision within two sessions
Security investment > \$[threshold]	SSC recommends	CFO / CEO approval; Board notification if material
Regulatory breach notification decision	SSC recommends; CEO and Legal approve	Immediate CEO escalation; Board notification

7. Reporting

The SSC Chair (CISO) produces a monthly summary report to the CEO covering: decisions taken, open risks, action items and any matters requiring CEO attention. A quarterly SSC report is included in the Board Audit and Risk Committee pack, covering: policy decisions, risk exceptions approved, cross-functional resolutions, and programme progress.

4B. Sample Agenda — SSC Inaugural Meeting

Field	Detail
Meeting	Security Steering Committee — Meeting 01
Date / Time	Tuesday [Date to be confirmed], 10:00 – 11:30 WAT
Location	GHC Executive Boardroom / Video Conference Link
Chair	CISO
Secretary	GRC Manager (Mark Johnson)
Distribution	All SSC members

R e f	Agenda Item	Owner	Time	Action Required
1 0	Welcome, introductions and apologies	CISO	5 min	Note attendance and apologies; confirm quorum
2 0	Terms of Reference — adoption	CISO / GRC Manager	10 min	Members to approve Terms of Reference; document as first formal SSC decision
3 0	Action log from previous meeting	GRC Manager	5 min	N/A — inaugural meeting (standing item for future meetings)
4 0	Security Posture Dashboard — Briefing	CISO	10 min	Note posture (AMBER); no formal decision required; context for item 5.0
5 0	KEY ITEM: Password Policy Dispute — CTO vs. IT Manager	CISO	25 min	DECISION REQUIRED — see briefing paper at Annex A
5 1	— Briefing: Current proposed policy (16-char, 30-day rotation, no password manager)	IT Manager	5 min	Presented for information
5 2	— Briefing: CTO counter-proposal (MFA + password manager)	CTO	5 min	Presented for information
5 3	— Governance framework analysis (NIST SP 800-63B / NCSC guidance)	CISO	5 min	SSC to note evidence base
5 4	— Discussion and SSC decision on password policy direction	Chair	10 min	FORMAL VOTE — record outcome; assign implementation lead and timeline
6 0	Security programme roadmap priorities — Q4 2025 carry-over	CISO	10 min	Members to note priorities; CFO/CEO to confirm budget envelope
7 0	Compliance update — HIPAA readiness position	GRC Manager	10 min	Note status; agree actions if gaps identified
8 0	Any other urgent business	Chair	5 min	Items must be notified to Chair before meeting
9 0	Next meeting date; action log review	GRC Manager	5 min	Confirm date, owners and deadlines for all actions

Annex A Note — Password Policy Technical Brief (Item 5.0)

SSC evidence base for deliberation: According to NIST SP 800-63B (Digital Identity Guidelines), periodic password rotation is not recommended in general-purpose accounts as it results in patterned passwords and post-it notes (NIST, 2017). The same recommendation from NCSC of the UK recommends the use of MFA as being more efficient than regular password changes (NCSC, 2023). The requirement of a 16-character length of passwords is in line with the NIST guidelines for password length. The approach suggested by the CTO,

which includes long passphrases, password manager and MFA, has a stronger evidence base than the password rotation requirement of the IT Manager.

4C. CEO Briefing Note — Security Steering Committee

Field	Detail
To	Sarah Chen, Chief Executive Officer
From	CISO / Information Security Programme
Subject	Security Steering Committee — Purpose, Conflict Resolution and Strategic Alignment
Date	11 September 2026

Sarah,

The Security Steering Committee (SSC) serves as the formal response that the GHC has built in order to overcome the governance gap that you have identified: ad hoc decisions in the area of security made at departmental level without cross-functional resolution process. This is a regular (once a month), quorate and minuted forum in which the heads of IT, Technology, Finance, Development, HR and Legal, along with CISO, are able to discuss any issues related to security, apply governance framework consistently and make documented decisions. The CTO versus IT Manager password dispute case is the best example of why such a forum is needed. Without an SSC, such disputes remain unresolved, or settled by the person who can impose his/her position better. The dispute will be considered at the first SSC meeting according to the current international guidance (NIST SP 800-63B; NCSC 2023) and a documented decision will be reached, which will be implemented by both parties as it was discussed and decided upon.

Strategic alignment comes from the fact that any important decision regarding security is reviewed in terms of the company strategy. A security control that hinders the release of a product or the integration of a customer will be brought to light and weighed in terms of risk rather than being imposed unilaterally. Likewise, a business request that poses undue risk will be considered and qualified rather than rejected outright. And that is why the SSC is the means by which security partners with business, thereby contributing directly to the strategic objectives of growth, efficiency, and innovation, while at the same time remaining disciplined with regards to governance.

Best Regards,

Chief Information Security Officer, GlobalHealth Connect

TASK 5 — GOVERNANCE MATURITY ASSESSMENT

5A. Current-State Maturity Assessment

Maturity ratings are based on the simplified five-level scale defined in the laboratory brief, corroborated against ISACA COBIT 2019 governance domain descriptors and the NIST Cybersecurity Framework 2.0 Implementation Tier guidance. Evidence is drawn from the interview summary data provided.

Domain	Level	Rating	Evidence and Justification
Policy & Documentation	1 – Ad Hoc	▼ AD HOC	The policies are uncoordinated and have been derived from two acquisitions. There is no master list of policies, there is no policy ownership scheme, there is no policy review process defined. The employees do not know which policy covers their operations.
Roles & Responsibilities	1 – Ad Hoc	▼ AD HOC	The security ownership has been implicitly assigned to anyone that sees the issue. There has been no CISO, no RACI, no role specifications for security. There has been no mapping of post-acquisition roles. The near-miss situation is an indication that no one had the idea who would lead the response.
Risk Management	1 – Ad Hoc	▼ AD HOC	The organisation recognises risk only in response to incidents. There is no risk register, there is no threat modeling, there is no risk assessment methodology. The risk decision-making is intuitive at the departmental level and is not visible enterprise-wide and no risk appetite defined.
Metrics & Reporting	2 – Initial	▷ INITIAL	Technical metrics are in place (as illustrated by six-month data provided). However, metrics are not translated into business value and are not reported to the board and have operational utility and no strategic utility. There are metrics in the form of data, but not in the form of governance intelligence.
Training & Awareness	2 – Initial	▷ INITIAL	There are annual mandatory training sessions, and participation has increased from 45% to 70%. Training is, however, generic and is not supplemented by phishing simulation exercises and has no impact measured on staff behavior. Engagement is partial and the program has no structured approach and measures of effectiveness.
Compliance	2 – Initial	▷ INITIAL	Healthcare regulatory requirements are known, and Mark Johnson does some compliance activities. Compliance activities are audit-driven; preparation increases before audits and becomes relaxed after audits. There is no continuity for compliance monitoring and/or a compliance calendar.

Summary: The maturity level of GHC is at level 1 (Ad Hoc) for three basic domains – Policy, Roles, and Risk Management, whereas, for the remaining three operational domains, it is at level 2 (Initial). On average, the maturity of all the six domains is around 1.5. This clearly depicts that this organisation has grown at a much faster pace than its governance maturity. The key risk is that level 1 maturity for the Policy and Risk domains invalidates any other maturity improvement because training, measurements and compliance depend on a sound policy base.

5B. 12–18 Month Maturity Improvement Roadmap

The roadmap targets Level 3 (Defined) across all six domains by Month 18. Initiatives are sequenced to address foundational gaps first, enabling subsequent improvements to be built on stable governance structures.

Initiative 1: Establish Governance Foundation (Months 1–4)

Field	Detail
Objective	Appoint a CISO, establish the SSC, and create the governance infrastructure upon which all other improvements depend.
Key Activities	(1) CISO recruitment and appointment. (2) SSC inaugural meeting and Terms of Reference adoption. (3) Development of Information Security Charter, approved by CEO and Board. (4) Design and socialise RACI matrix across all departments. (5) CISO conducts initial 30-day security programme review and presents findings to SSC.
Domains Addressed	Roles & Responsibilities (target: Level 3); Policy & Documentation (initial uplift to Level 2)
Measurable Expected Outcome	By Month 4: CISO in post; SSC meeting monthly; Charter board-approved; RACI distributed and acknowledged by all department heads; GHC has moved from Level 1 to Level 2+ in Roles & Responsibilities.
Owner	CEO (appointment); CISO (programme delivery)
Dependencies	Board approval of CISO budget; CEO priority support for SSC launch

Initiative 2: Policy Framework Consolidation (Months 2–6)

Field	Detail
Objective	Replace the inconsistent inherited policy landscape with a coherent, tiered policy framework aligned to GHC's risk profile and regulatory obligations.
Key Activities	(1) Perform a policy inventory for all existing policies, inherited and organic. (2) Establish policy hierarchy (Charter > Policy > Standard > Procedure) and naming convention. (3) Prioritize and write/update eight essential security policies: Acceptable Use; Access Control; Incident Response; Data Classification; Third-Party Security; Cryptography; Change Management; Business Continuity. (4) SSC approval of each policy. (5) Make public through publication in GHC Document Management System with a review calendar. (6) Inform all personnel through briefing sessions.
Domains Addressed	Policy & Documentation (target: Level 3)
Measurable Expected Outcome	By Month 6: All eight core policies approved and published; 100% of staff notified; policy review calendar active; policy register maintained by GRC Manager; no orphaned legacy policies remaining.
Owner	CISO / GRC Manager (Mark Johnson)
Dependencies	CISO in post (Initiative 1); SSC operational for approval workflow

Initiative 3: Risk Management Programme Launch (Months 3–8)

Field	Detail
Objective	Move GHC from reactive, incident-triggered risk awareness to a proactive, documented and repeatable enterprise risk management process.
Key Activities	(1) Develop GHC risk appetite statement (jointly developed with CFO and CEO; endorsed by Board). (2) Implement ISO/IEC 27005:2022 as risk assessment approach. (3) Carry out initial enterprise information security risk assessment in all six areas of operation. (4) Develop risk register in GRC system (or document); designate risk owners. (5) Initiate

Field	Detail
	quarterly risk review cycle in SSC. (6) Incorporate risk assessment into project and product launch gateway process (in collaboration with CTO).
Domains Addressed	Risk Management (target: Level 3)
Measurable Expected Outcome	By Month 8: Risk appetite statement board-approved; initial risk assessment completed; risk register maintained with named owners; quarterly risk review embedded in SSC agenda; all new projects require CISO risk sign-off.
Owner	CISO / GRC Manager
Dependencies	CISO in post; CFO engagement for risk appetite definition; CTO cooperation for project gateway integration

Initiative 4: Security Awareness Programme Uplift (Months 4–10)

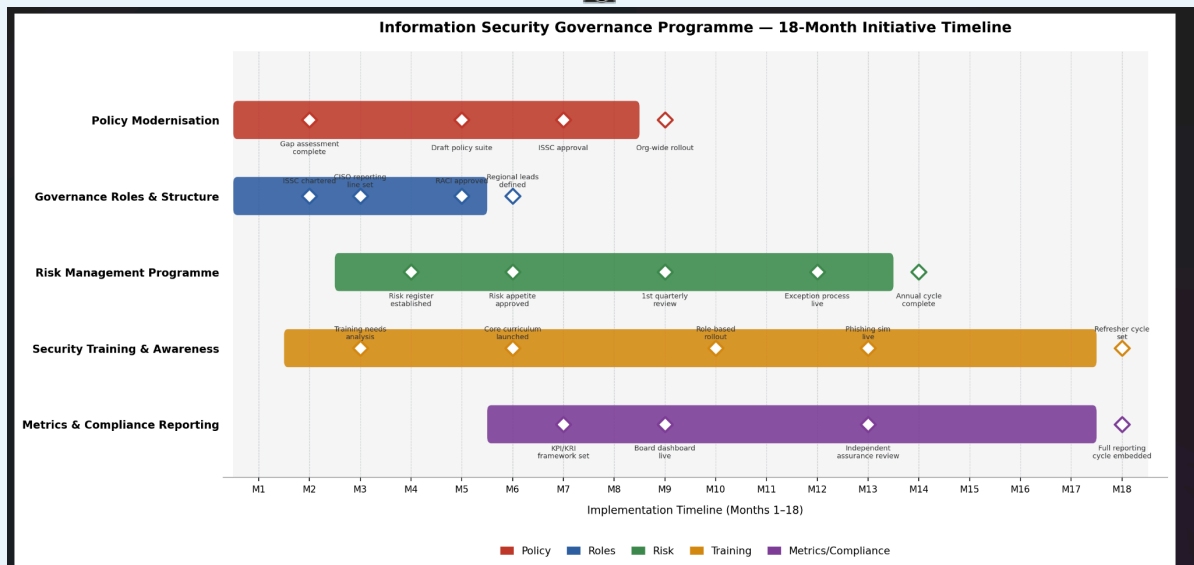
Field	Detail
Objective	Move from a compliance-driven annual training model to a continuously effective, behaviour-change-focused security awareness programme.
Key Activities	(1) Develop and implement security training sessions based on roles (clinical vs. development vs. finance vs. leadership paths). (2) Initiate monthly phishing simulation program (automated; metrics per department). (3) Implement quarterly security bulletin for all employees. (4) Implement security champions per department (Jane Doe as champion for Development Department first). (5) Report training attendance monthly to SSC; phishing simulation click-through rates quarterly to SSC.
Domains Addressed	Training & Awareness (target: Level 3)
Measurable Expected Outcome	By Month 10: Training completion rate $\geq 95\%$; phishing simulation click rate reduced by $\geq 40\%$ from baseline; security champions nominated in all departments; completion and effectiveness metrics reported to SSC monthly.
Owner	CISO / HR Manager (Robert Green)
Dependencies	Training platform selection and budget approval; HR cooperation on completion tracking

Initiative 5: Metrics, Reporting and Compliance Programme Maturation (Months 6–18)

Field	Detail
Objective	Elevate metrics from technical data collection to Board-level governance intelligence, and transform compliance from audit-driven to continuously monitored.
Key Activities	1. Formally define and document KPIs for five security-related board metrics (as outlined in Task 3 methodology). 2. Establish monthly Executive Security Dashboard for CEO/CFO/CTO; Quarterly cycle for Board reporting. 3. Establish HIPAA compliance calendar including monthly control review schedule. 4. Continuous compliance monitoring for the top three priority HIPAA domains (Access Control, Audit Logging, Transmission Security). 5. Annual third party compliance assessment. 6. Month 18: First annual self-assessment of maturity presented to Board Audit Committee.
Domains Addressed	Metrics & Reporting (target: Level 3); Compliance (target: Level 3)
Measurable Expected Outcome	Month 18 – Security Report delivered quarterly to Board on approved template; Monthly Executive Dashboard prepared with 100% metric data completion; HIPAA Continuous Monitoring implemented in 3 high priority domains; no findings from regulation due to missing control in compliant domains; self-maturity assessment proves Level 3 for all six domains.

Field	Detail
Owner	CISO / GRC Manager
Dependencies	Risk register operational (Initiative 3); CISO reporting cadence established (Initiative 1)

Roadmap Visual — Gantt Overview



12–18 month Gantt chart or initiative timeline here. Timeline should show five initiatives with monthly milestones across Months 1–18. Colour-code by domain: Red = Policy, Blue = Roles, Green = Risk, Orange = Training, Purple = Metrics/Compliance

5C. Board Executive Summary — GHC Governance Maturity

Field	Detail
To	GHC Board of Directors
From	CISO / Information Security Programme
Subject	Governance Maturity Assessment — Current State and Improvement Roadmap
Date	11 September 2026

The assessment of GHC's governance maturity indicates that the organisation operates at Level 1 (Ad hoc) in three out of six categories: Policy & Documentation, Roles & Responsibilities, and Risk Management; and at Level 2 (Initial) in the other three: Metrics & Reporting, Training & Awareness, and Compliance. Such findings are common for an organisation that has expanded quickly and made two acquisitions within a relatively short time frame; as a rule, investments in governance are delayed behind operations. But such current state cannot be sustained considering GHC's responsibilities in accordance with HIPAA, as well as the organisation's growth prospects, and the increasingly challenging threat environment based on the analysis of the six months security metrics database. In three out of six governance areas, the organisation lacks defined processes, process owners and use; these are precisely those factors that make the organisation susceptible to data breaches and enforcement.

The roadmap of five initiatives shared with the Board aims to reach Level 3 (Defined) in all six areas in 18 months' time. It is a reachable and budgeted target that starts with the two most important foundations – appointment of the CISO and consolidation of policies – and gradually goes to continuous compliance monitoring and reporting maturity. At Level 3, all security processes implemented by GHC will be defined, communicated, accountable to someone, and consistently used by GHC. It is the bare minimum requirement for such a healthcare organization in terms of governance and the basis GHC will have to prove its good faith compliance in front of any regulation. The Board should approve this roadmap, acknowledge the governance investment necessary to support this roadmap, and get quarterly updates on the progress from the CISO starting from the next Board meeting.

REFERENCES

- Calder, A. and Watkins, S. (2010) IT Governance: An International Guide to Data Security and ISO27001/ISO27002. 5th edn. London: Kogan Page.
- Financial Reporting Council (FRC) (2024) UK Corporate Governance Code 2024. London: FRC. Available at: <https://www.frc.org.uk> (Accessed: 9 September 2026).
- IBM Security (2024) Cost of a Data Breach Report 2024. Armonk, NY: IBM Corporation.
- International Organization for Standardization (ISO) (2022) ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection. Geneva: ISO.
- International Organization for Standardization (ISO) (2022) ISO/IEC 27005:2022 — Information Security Risk Management. Geneva: ISO.
- ISACA (2023) COBIT 2019 Framework: Governance and Management Objectives. 2nd edn. Schaumburg, IL: ISACA.
- National Institute of Standards and Technology (NIST) (2017) Special Publication 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management. Gaithersburg, MD: NIST. Available at: <https://pages.nist.gov/800-63-3> (Accessed: 9 September 2026).
- National Institute of Standards and Technology (NIST) (2024) Cybersecurity Framework (CSF) 2.0. Gaithersburg, MD: NIST. Available at: <https://www.nist.gov/cyberframework> (Accessed: 9 September 2026).
- National Cyber Security Centre (NCSC) (2023) Password Administration for System Owners. London: NCSC. Available at: <https://www.ncsc.gov.uk> (Accessed: 9 September 2026).
- United States Department of Health and Human Services (HHS) (2022) Summary of the HIPAA Security Rule. Washington, DC: HHS Office for Civil Rights. Available at: <https://www.hhs.gov/hipaa> (Accessed: 9 September 2026).
- United States Department of Health and Human Services (HHS) (n.d.) 45 CFR §164.308 — Administrative Safeguards. Washington, DC: HHS.
- United States Department of Health and Human Services (HHS) (n.d.) 45 CFR §164.410 — Notification by a Business Associate. Washington, DC: HHS.